

# BRIEFINGS

---

**black hat**

## Threat Modeling LLMs The PHANTOM-B Approach

Adam Shostack

# Threat Modeling LLMs

## The PHANTOM-B Approach

Blackhat USA  
August 2026

Adam Shostack



THE EMPEROR IS MOST DISPLEASED WITH YOUR LACK OF AI PROGRESS

# Agenda

---

- Threat modeling context
- Threat modeling LLMs
- The PHANTOM-B approach
  - Why PHANTOM-B?
  - What is PHANTOM-B?

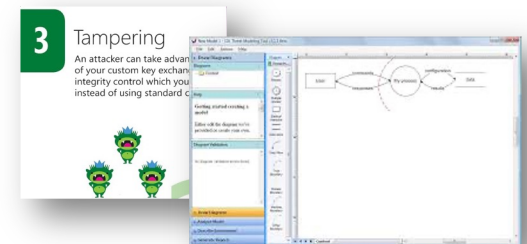
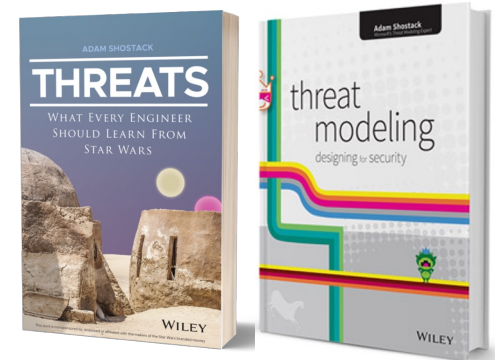
# About

**SHOSTACK**  
+ ASSOCIATES



Don't just understand security.  
Build it in.

**W**  
UNIVERSITY of WASHINGTON



# Threat modeling context

# What is threat modeling?

---

- Using models to help us think about security
- The “measure twice, cut once” of engineering
- Applies to both tech you produce or tech you operate
- Applies to LLMs you train or get from Huggingface

# How do we threat model?

---

- Four Question Framework
  - What are we working on?
  - What can go wrong?
  - What are we going to do about it?
  - Did we do a good job?
- Widely adopted: Industry + gov standard
  - Anthropic, Google, Amazon, MITRE, FDA + more
- [Threatmodelingmanifesto.org](https://threatmodelingmanifesto.org) + [Shostack.org/whitepapers](https://shostack.org/whitepapers)



# Why bother threat modeling LLMs

---

- “Won’t the LLM threat model?”
- “My skills say only write secure code!”
- “Going fast gets me promoted”
- So why bother threat modeling LLMs?

# Your executives are really scared

---

- AI disruption is real
- Maybe we're in a bubble, maybe not?
- FOMO is rampant
- We have to ship AI stuff!

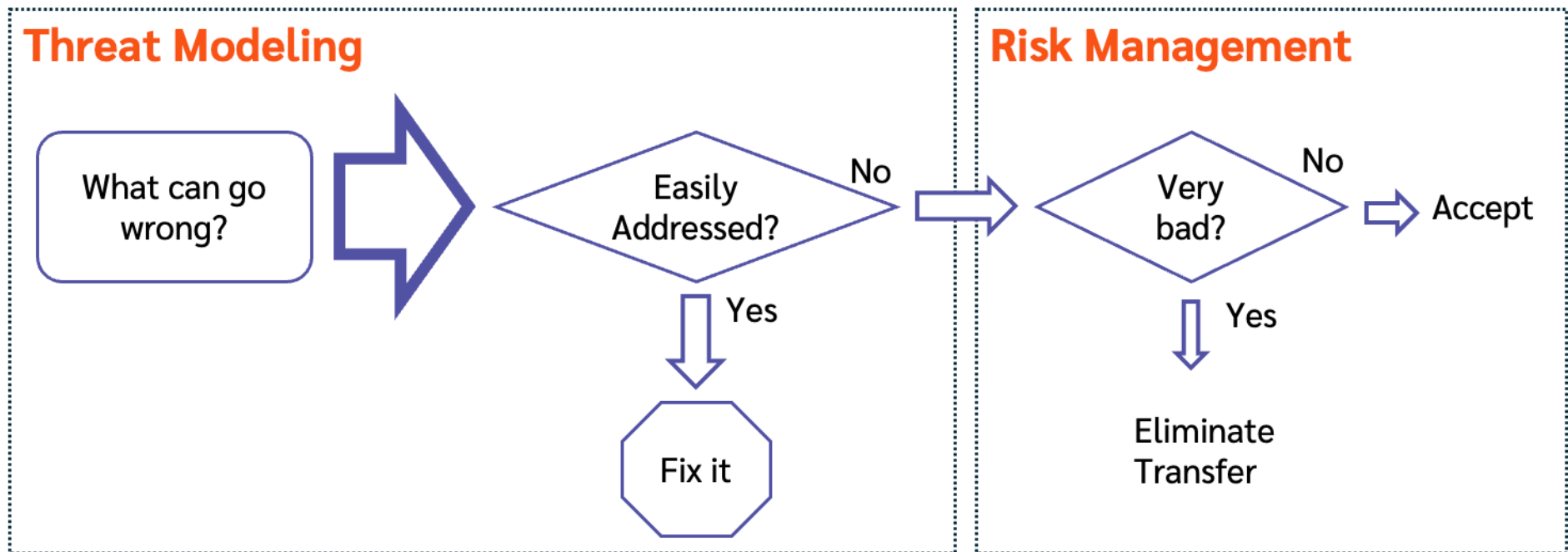
# Business works better with threat modeling

---

- Your developers + leaders don't understand what can go wrong
- LLMs change your security posture
  - The posture of the code being produced
  - The strengths and weaknesses of the latest models
- Cognitive debt is getting worse
- Change continues to accelerate
- Staying focused on what we're working on is crucial

Threat modeling  
is the security technique that  
best survives AI disruptions

# Threat modeling can drive risk management



LLMs also disrupt  
threat modeling

# PHANTOM-B origin story (preview)

---

- AI disrupted threat modeling in two ways
  - Using AI to threat model
  - Threat modeling AI systems
- Clients looking for
  - AI focused training
  - Lower training cost (“Can we make this faster?”)
- Analyzing the state of the art
  - Reviewed and wrote at length about available threat catalogs

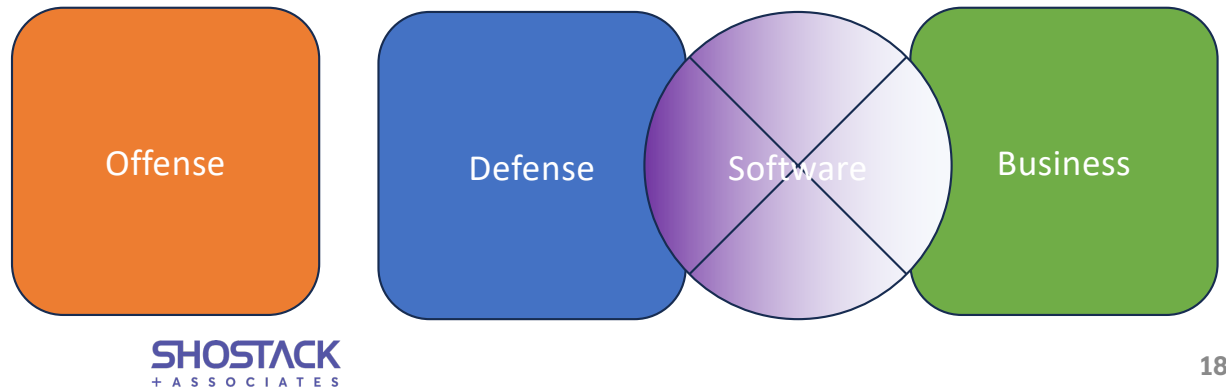
# Threat modeling LLMs



# Four scenarios: Using AI in...

---

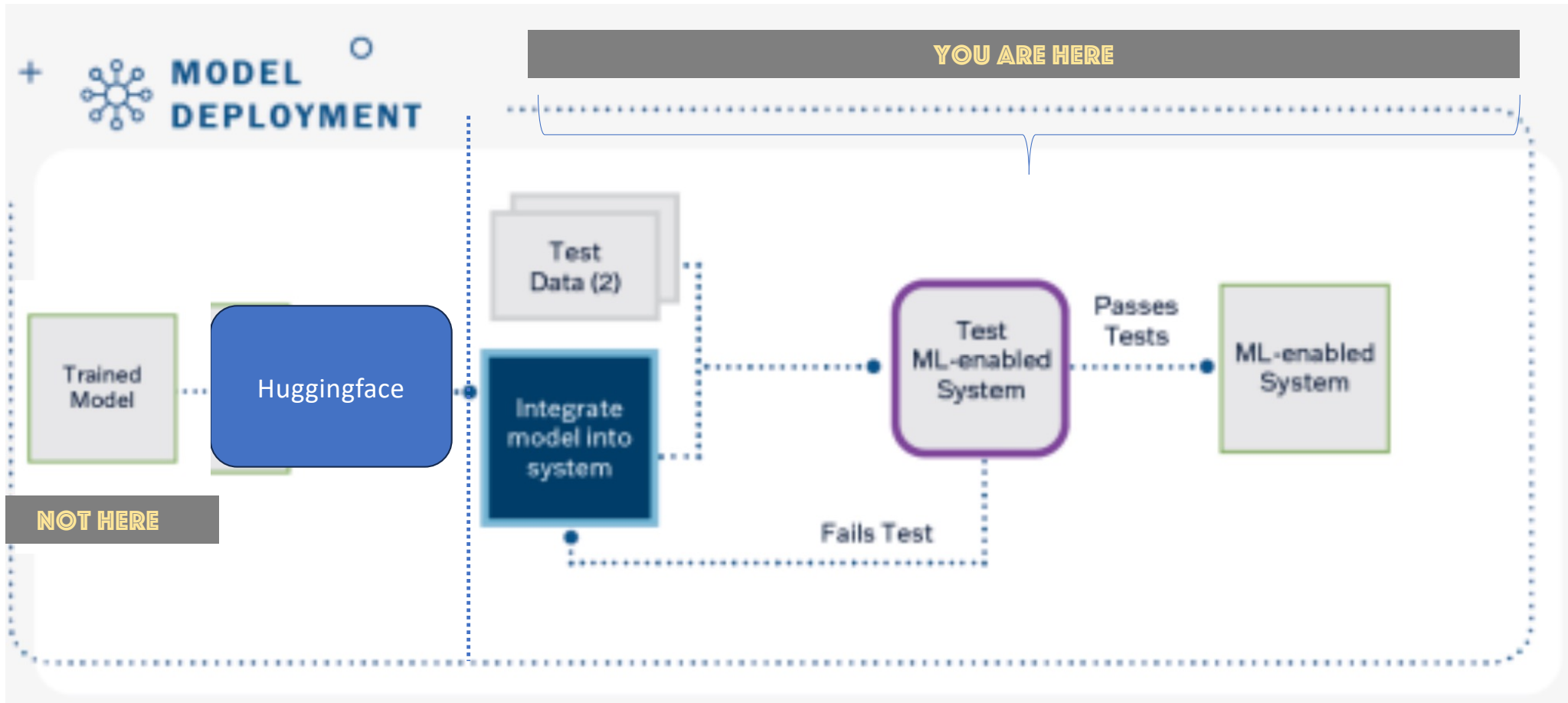
- Offense (write me a phishing email/malware/etc)
- Defense (anti-spam, Microsoft defender copilot)
- Software development
- Business (Today's focus)



# What are we working on with AI?

---

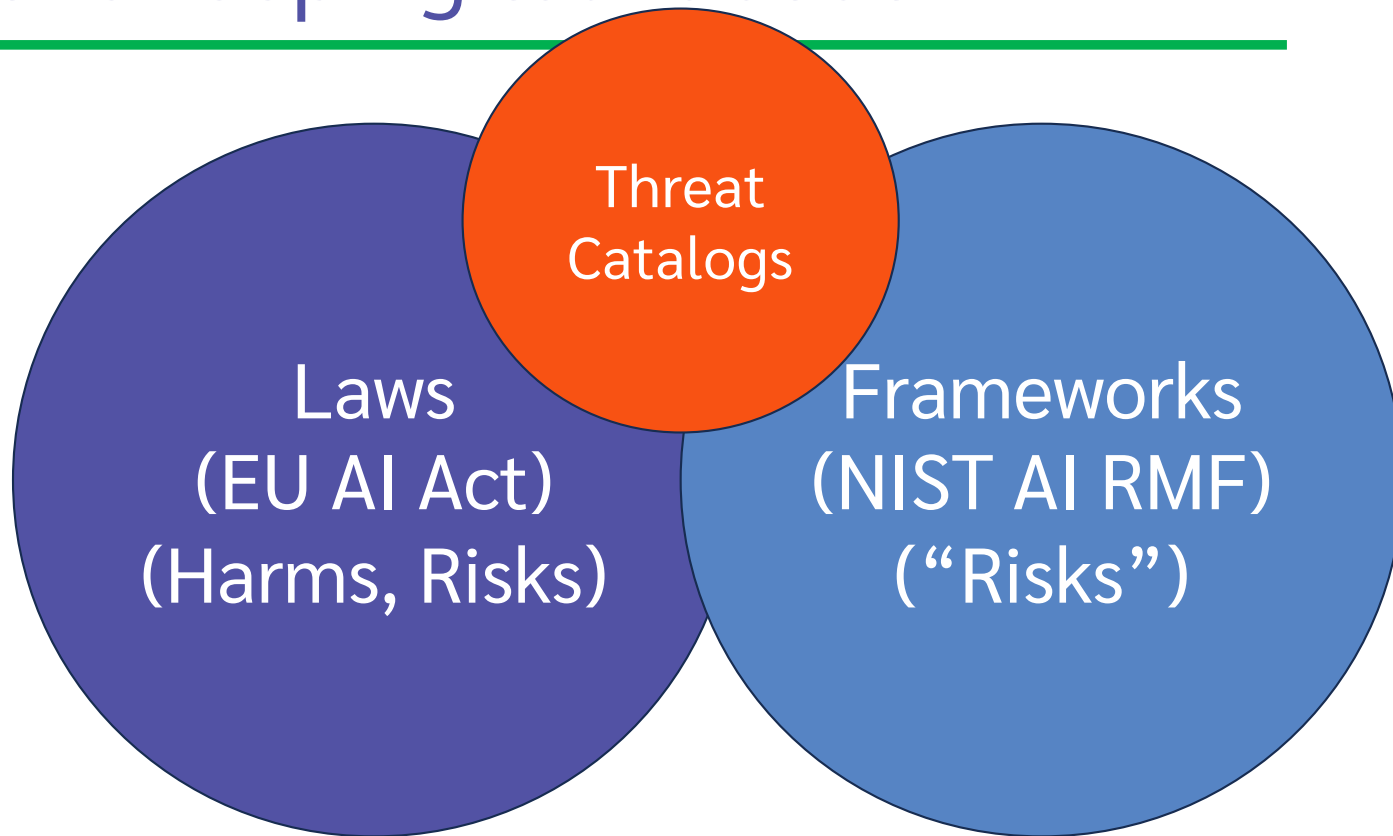
- Adding an LLM to our business
  - Chatbots
  - Document processing
  - Search
  - Decision making
- We should ask “what can go wrong?”



# What can go wrong with AI?

# Lots of sweeping talk about AI

---



# What are **WE** working on?

---

Executives

Laws  
(EU AI Act)  
(Harms, Risks)

Frameworks  
(NIST AI RMF)  
("Risks")

Engineers

Threat  
Catalogs

SHOSTACK  
+ ASSOCIATES

# Many AI threat catalogs — Ways to answer “what can go wrong”

---

- Berryville’s ML + LLM Risk Analyses
- OWASP Top 10 LLMs
- OWASP AI Exchange
- MITRE ATLAS
- NIST AIML E2025
- Google SAIF
- ...



Structured ways to answer  
“What can go wrong”  
More organized than “We’ll red team it”

# The PHANTOM-B Approach



# Why PHANTOM-B?

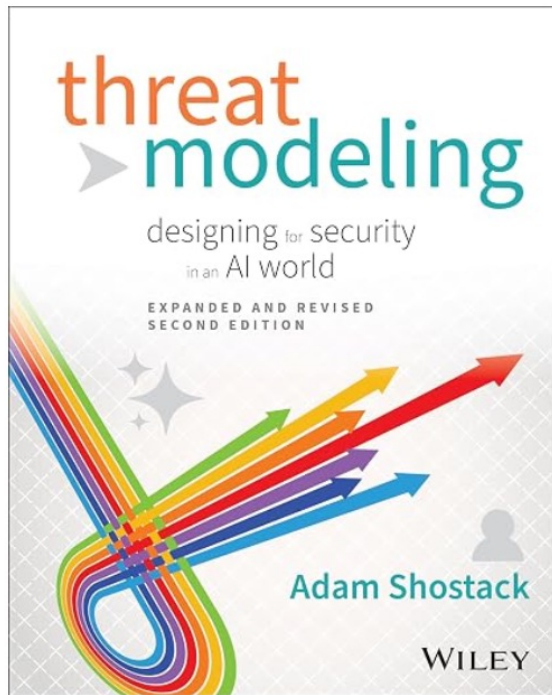
~~The alternatives suck~~  
All models are wrong,  
some models are useful.

# What goes wrong with TM structures? (Each “for some users”)

---

- High training cost (learning is hard)
- Hard to use (even after training)
- Not LLM/AI focused
- Duplicative/overlaps other frameworks/security work
- Raises threats which are irrelevant/can't fix/won't fix
  - “Academic”
- Low return on investment
- Require software support

# PHANTOM-B origin story (1/2)



## Threat Modeling: Designing for Security in an AI World

by [Adam Shostack](#) (Author) | Format: Paperback



✓ **Savings Pre-order Price Guarantee.** [Terms](#)

**A major update to the definitive guide on threat modeling techniques for secure by design**

More than just a second edition, *Threat Modeling: Designing for Security in an AI World* thoroughly updates and expands on Adam Shostack's classic text and structured approach to analyzing and designing systems, software, and services for security flaws to address threats and technologies that didn't exist when the first edition published. Most notably every reader will benefit from two new chapters covering using LLMs to threat model and exploring threats to LLMs, AIs, and ML Models themselves. There's a new deep focus on agile and an expansion of who's involved in threat modeling, now including non-technical product owners. All told, half of this edition is completely new or heavily revised.

**SHOSTACK**  
+ ASSOCIATES

## PHANTOM-B origin story (2/2)

---

- Built and iterated over several versions
  - On our own projects
  - With hyperscalers, globally significant banks and others
- Earlier versions didn't meet our release quality bar
  - TRAPHOME
  - PHANTOMED

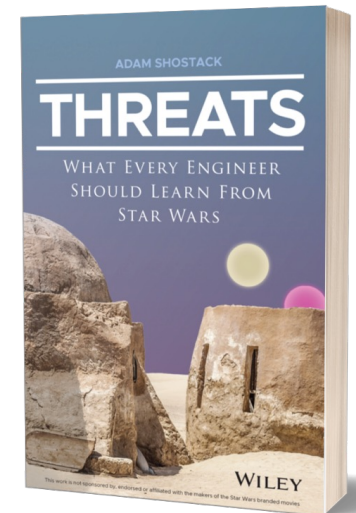
# PHANTOM-B is inspired by STRIDE

- [Spoofing, Tampering, Repudiate, Info disclose, DoS, Expand Authority]
- Time-tested + durable mnemonic from Kohnfelder + Garg
- STRIDE remains broadly applicable

## STRIDE per Element



|                                                                                                        | Spoof | Tamper | Repudiate | Info Disclose | Deny Service | EoP |
|--------------------------------------------------------------------------------------------------------|-------|--------|-----------|---------------|--------------|-----|
| External Entity<br> | ●     |        | ●         |               |              |     |
| Process<br>         | ●     | ●      | ●         | ●             | ●            | ●   |
| Data Store<br>      |       | ●      | ?         | ●             | ●            |     |
| Dataflow<br>        |       | ●      |           | ●             | ●            |     |



# PHANTOM-B identifies: “What can go wrong deploying AI?”

---

Prompt injection

Hallucination

Anthropomorphization

Non-explainable

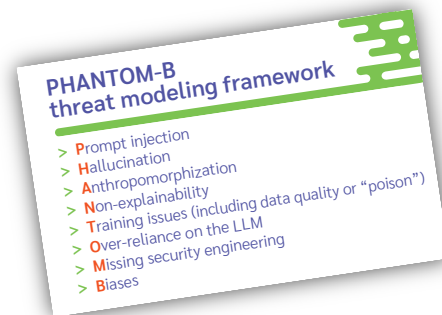
Training issues

Over-reliance

Missing security engineering

Bias

- Free to use (CC-BY)
- Memorable
- 100% threat-focused
- Fits on a wallet card



# Focused on using/calling LLMs

---

- Under your control (on your GPUs or Amazon Bedrock)
  - “Downloaded from Huggingface”
- An LLM provider offers, such as ChatGPT or Claude
  - Via the API
  - (Not useful for “using chatgpt.com in a browser”)



# Prompt injection

---

- Controlling LLM behavior via input
  - Code/data confusion
- More than just funny stories
  - Bypasses your controls and gets the LLM to violate rules
  - Unlike SQLi, no deterministic, proven defenses exist

# Hallucination

---

- ~~The LLM makes stuff up~~
- The LLM makes up stuff we don't like:
  - Bad code
  - False citations

# Anthropomorphization

---

- Means treating the LLM as a human
- This is great product design
  - Use of language and “I” are a facade
- LLMs are token generators
  - Not concept models
  - Not thinking beings
- “Don’t do X” for humans and token generators
- No guilt, no learning, no desire to improve

---

## ByteDance and Alibaba to disable humanlike AI custom agents as new rules loom

With Beijing's rules on humanlike AI interaction services taking effect on July 15, Doubao and Qwen move to disable customised features



Chew up tokens!

arXiv:2604.07729 (cs)

[Submitted on 9 Apr 2026]

### Emotion Concepts and their Function in a Large Language Model

Nicholas Sofroniew, Isaac Kauvar, William Saunders, Runjin Chen, Tom Henighan, Sasha Hydrie, Craig Citro, Adam Pearce, Julius Tarng, Wes Gurnee, Joshua Batson, Sam Zimmerman, Kelley Rivoire, Kyle Fish, Chris Olah, Jack Lindsey

# Non-explainable

---

- We can't tell why we got important results
- Explainability as “why did it actually do that?”
- Not asking “why did you do that?”
  - LLMs produce plausible answers, not accurate ones
- More important as LLM makes decisions
- Explainability for various audiences
  - Data scientists
  - End users (eg, medical LLM explaining — accurately — to patients + doctors)
  - Courts

# Training issues

---

- LLMs do better as we give them more data
- So your LLM was probably trained on Stack Exchange, Reddit + Twitter
- Good luck finding that in the model card!
- Data poisoning is “scale invariant” with 250 documents

Souly, et al, Poisoning Attacks on LLMs Require a Near-constant Number of Poison Samples, 8 October 2025,  
<https://arxiv.org/abs/2510.07192>

# Over-reliance on the LLM

---

- We trust the LLM and don't pay close attention
- LLMs generate a lot of text / code
  - Hard to focus on
  - Often okay
- Hard to remain vigilant
- Your code, your brand 🙌
- Making decisions about hiring, college admissions, arrests... 🤯

---

Investigations | Jul 17 2026

# **Black prisoners are assigned harsher living conditions in Ontario jails—thanks to AI**

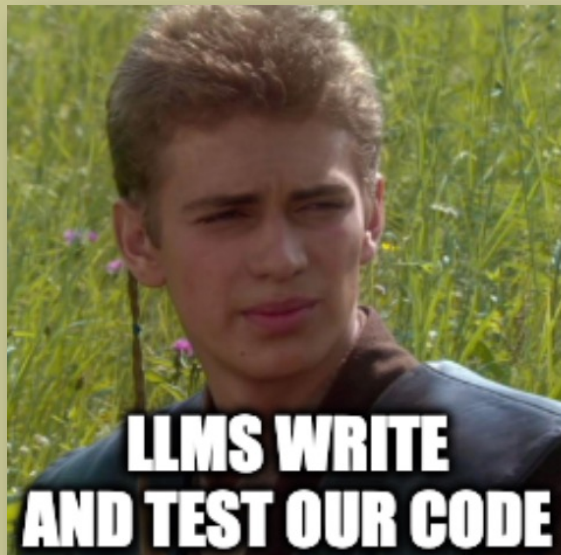
Ontario jails are using a program that claims it can predict prisoners' behaviour, disproportionately putting Black prisoners in higher-security facilities



# Missing security engineering

---

- We assume you still have software security, this ties to it
- LLMs are software
  - All software has bugs
  - Some bugs are security-relevant
- PHANTOM-B augments STRIDE, kill chains, SDLs
- PHANTOM-B was aggressively de-duped
  - For example, MCP has lots of spoofing and expansion of authority issues
  - Not included in PHANTOM-B because you have other security engineering



# Bias

---

- Does the LLM treat groups unevenly?
- Does it display the board of directors as white men?
  - How about the janitorial staff?
- Inherited from data pipeline
  - Bias in the data, cleaning, training, tuning processes
  - You can't remove it, but you can understand it
- Often in the eye of the beholder
- Defined by law. Certain decisions have “protected groups”

# PHANTOM-B identifies: “What can go wrong deploying AI?”

---

- Prompt injection
- Hallucination
- Anthropomorphization
- Non-explainable
- Training issues
- Over-reliance
- Missing security engineering
- Bias

# Using PHANTOM-B

---

- “What can go wrong”
- Many broader than “the math”
- Product-manager or exec suite

# PHANTOM-B illustrates why TM matters

---

- Engineering requires tradeoffs between unsatisfiable constraints
  - Features, reliability, speed, cost, quality ... and security
  - Building security in is better than bolting-on controls
- Before you write (or vibe) a line of code, consider what can go wrong
  - Threat modeling lets you do this via the Four Questions
  - PHANTOM-B lets you do this for LLMs
- This gives you the most options for what are we going to do

# Summary

---

- Threat modeling enables strategic views of security
- What can go wrong with LLMs requires innovative approaches
- PHANTOM-B balances coverage + accessibility

# Bonus!

---

- Today: Book signing – bookstore, Breaker Rooms @ 12:45
- Thursday: AI Threat Modeling Community meetup
  - Noon tomorrow “The Convergence, Business Hall”



# Thank you!

# PHANTOM-B approach to LLM TM

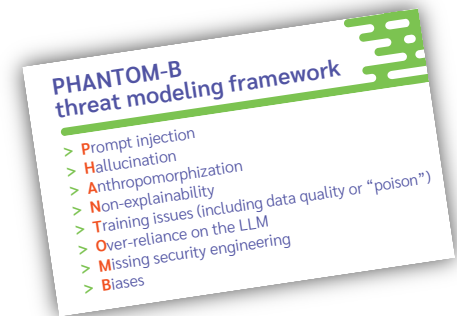
Blackhat USA August 2026

## Questions?

adam@shostack.org



Slides:  
[Shostack.org/blog](https://shostack.org/blog)



Wallet cards, book signing at  
Bookstore, 12:45 PM today

Meetup, The Convergence,  
Noon tomorrow

**SHOSTACK**  
+ ASSOCIATES

Supporting Materials

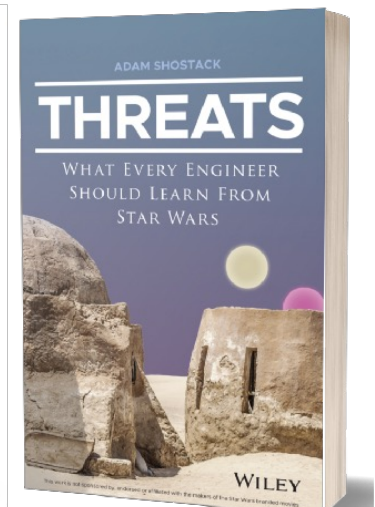
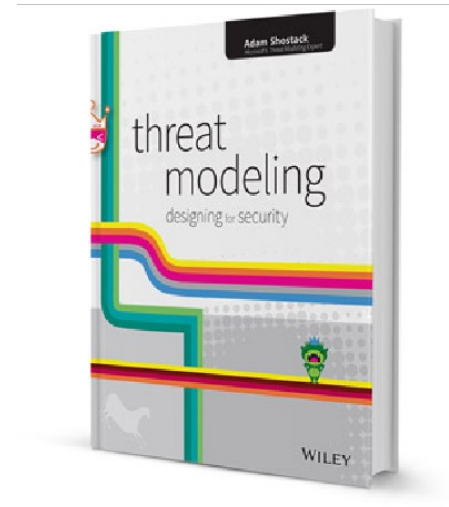
# Shostack + Associates

Don't just understand security.

Build it in.

# Free resources

- [shostack.org/resources](https://shostack.org/resources)
  - [shostack.org/blog](https://shostack.org/blog)
  - [youtube.com/c/Shostack](https://youtube.com/c/Shostack)
- 
- Books
  - LinkedIn Learning

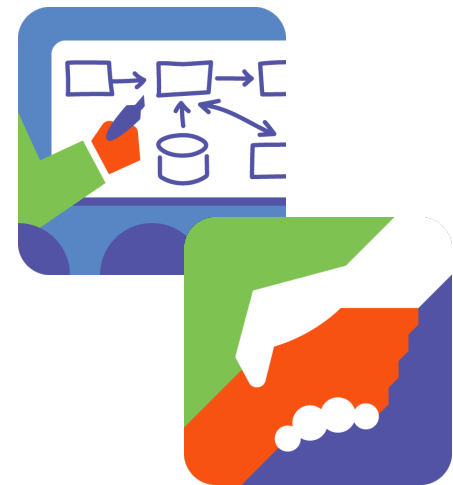


Books free at your library/various subscriptions; LinkedIn Learning via work

# Commercial offerings

---

- Training
  - From under an hour to multi-day
  - Live instruction or computer-based
  - In-person or distributed
  - Private corporate courses
- Accelerator
  - Culture change, process design
- Assessments + analysis



info@shostack.org

shostack.org/contact



backup

LLM01: 2025

## Prompt Injection

### LLM01:2025 Prompt Injection

A Prompt Injection Vulnerability occurs when user prompts alter the...

[Read More](#)

LLM02: 2025

## Sensitive Information Disclosure

### LLM02:2025 Sensitive Information Disclosure

Sensitive information can affect both the LLM and its application...

[Read More](#)

LLM03: 2025

## Supply Chain

### LLM03:2025 Supply Chain

LLM supply chains are susceptible to various vulnerabilities, which can...

[Read More](#)

LLM04: 2025

## Data and Model Poisoning

### LLM04:2025 Data and Model Poisoning

Data poisoning occurs when pre-training, fine-tuning, or embedding data is...

[Read More](#)

LLM05: 2025

## Improper Output Handling

### LLM05:2025 Improper Output Handling

Improper Output Handling refers specifically to insufficient validation, sanitization, and...

[Read More](#)

LLM06: 2025

## Excessive Agency

### LLM06:2025 Excessive Agency

An LLM-based system is often granted a degree of agency...

[Read More](#)

LLM07: 2025

## System Prompt Leakage

### LLM07:2025 System Prompt Leakage

The system prompt leakage vulnerability in LLMs refers to the...

[Read More](#)

LLM08: 2025

## Vector and Embedding Weaknesses

### LLM08:2025 Vector and Embedding Weaknesses

Vectors and embeddings vulnerabilities present significant security risks in systems...

LLM09: 2025

## Misinformation

### LLM09:2025 Misinformation

Misinformation from LLMs poses a core vulnerability for applications relying...

[Read More](#)

LLM10: 2025

## Unbounded Consumption

### LLM10:2025 Unbounded Consumption

Unbounded Consumption refers to the process where a Large Language...

[Read More](#)



|                                                                                                                                                                                                                  |                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                         |                                                                                                                                                                                                                                                         |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>LLM01: 2025</div> <div>Prompt Injection</div> <div>LLM01:2025 Prompt Injection</div> <div>A Prompt Injection Vulnerability occurs when user prompts alter the...</div> <div><a href="#">Read More</a></div> | <div>LLM02: 2025</div> <div>Sensitive Information Disclosure</div> <div>LLM02:2025 Sensitive Information Disclosure</div> <div>Sensitive information can affect both the LLM and its application...</div> <div><a href="#">Read More</a></div> | <div>LLM03: 2025</div> <div>Supply Chain</div> <div>LLM03:2025 Supply Chain</div> <div>LLM supply chains are susceptible to various vulnerabilities, which can...</div> <div><a href="#">Read More</a></div>                                                    | <div>LLM04: 2025</div> <div>Data and Model Poisoning</div> <div>LLM04:2025 Data and Model Poisoning</div> <div>Data poisoning occurs when pre-training, fine-tuning, or embedding data is...</div> <div><a href="#">Read More</a></div> | <div>LLM05: 2025</div> <div>Improper Output Handling</div> <div>LLM05:2025 Improper Output Handling</div> <div>Improper Output Handling refers specifically to insufficient validation, sanitization, and...</div> <div><a href="#">Read More</a></div> |
| <div>LLM06: 2025</div> <div>Excessive Agency</div> <div>LLM06:2025 Excessive Agency</div> <div>An LLM-based system is often granted a degree of agency...</div> <div><a href="#">Read More</a></div>             | <div>LLM07: 2025</div> <div>System Prompt Leakage</div> <div>LLM07:2025 System Prompt Leakage</div> <div>The system prompt leakage vulnerability in LLMs refers to the...</div> <div><a href="#">Read More</a></div>                           | <div>LLM08: 2025</div> <div>Vector and Embedding Weaknesses</div> <div>LLM08:2025 Vector and Embedding Weaknesses</div> <div>Vectors and embeddings vulnerabilities present significant security risks in systems...</div> <div><a href="#">Read More</a></div> | <div>LLM09: 2025</div> <div>Misinformation</div> <div>LLM09:2025 Misinformation</div> <div>Misinformation from LLMs poses a core vulnerability for applications relying...</div> <div><a href="#">Read More</a></div>                   | <div>LLM10: 2025</div> <div>Unbounded Consumption</div> <div>LLM10:2025 Unbounded Consumption</div> <div>Unbounded Consumption refers to the process where a Large Language...</div> <div><a href="#">Read More</a></div>                               |

# Berryville Institute of Machine Learning

---

- Think tank of security + ML experts studying machine learning sec  
<https://berryvilleiml.com/>
- Taxonomy of threats (2019)
  - Manipulation of input, data, models
  - Extraction of input, data, models
- Architectural Risk Analysis of a generic ML system (2023)
- ARA for LLM (2024)
- Elevation of ML card deck!  
<https://agilestationery.com/collections/security/products/elevation-of-machine-learning-security-card-game>
- Annotated bibliography

# ATLAS Matrix for AI Systems

Subtechniques

Expand All

Collapse All

Filter by maturity



Feasible

Demonstrable

## Reconnaissance &

8 techniques

Active Scanning &  
Gather RAG-Indexed Targets  
Gather Victim Identity Information &  
Search Application Repositories  
Search Open AI Vulnerability Analysis  
Search Open Technical Databases &  
Search Open Websites/Domains &  
Search Victim-Owned

## Resource Development &

13 techniques

Acquire Infrastructure ||  
Acquire Public AI Artifacts ||  
Develop Capabilities & ||  
Establish Accounts &  
LLM Prompt Crafting  
Obtain Capabilities & ||  
Poison Training Data  
Publish Hallucinated Entities

## Initial Access &

7 techniques

AI Supply Chain Compromise ||  
Drive-by Compromise &  
Evade AI Model  
Exploit Public-Facing Application &  
Phishing & ||  
Prompt Infiltration via Public-Facing Application  
Valid Accounts &

## AI Model Access

4 techniques

AI Model Inference API Access  
AI-Enabled Product or Service  
Full AI Model Access  
Physical Environment Access

## Execution &

6 techniques

AI Agent Clickbait  
AI Agent Tool Invocation  
Command and Scripting Interpreter &  
Deploy AI Agent  
LLM Prompt Injection ||  
User Execution & ||

## Persistence &

9 techniques

AI Agent Context Poisoning ||  
AI Agent Tool Data Poisoning  
AI Agent Tool Poisoning  
LLM Prompt Self-Replication  
Manipulate AI Model ||  
Modify AI Agent Configuration  
Poison Training Data  
Prompt Infiltration via Public-Facing

## Privilege Escalation &

4 techniques

AI Agent Tool Invocation  
Escape to Host &  
LLM Jailbreak  
Valid Accounts &

## Defense Evasion &

15 techniques

AI Supply Chain Reputation Inflation  
AI Supply Chain Rug Pull  
Corrupt AI Model  
Delay Execution of LLM Instructions  
Evade AI Model  
Exploitation for Defense Evasion &  
False RAG Entry Injection  
Impersonation &

## Credential Access &

6 techniques

AI Agent Tool Credential Harvesting  
Credentials from AI Agent Configuration  
Exploitation for Credential Access &  
OS Credential Dumping &  
RAG Credential Harvesting  
Unsecured Credentials &

## Discovery &

9 techniques

Cloud Service Discovery &  
Discover AI Agent Configuration ||  
Discover AI Artifacts  
Discover AI Model Family  
Discover AI Model Ontology  
Discover AI Model Outputs  
Discover LLM Hallucinations  
Discover LLM System ||